

08 BOM Squad

In this assignment, you will examine different aspects of using Software Composition Analysis (SCA) to manage risk from third-party, open source components.

Part 1: Binary SCA of Telegram

In BDBA, I have already analyzed the Telegram Linux desktop application available from [the official downloads page](#). The BDBA analysis is here:

<https://protecode-sc.com/#/product/24174275/analysis>

Take a look through the components and vulnerabilities reported by BDBA.

Pretend you are a security engineer. What recommendations would you make to the development team? Keep in mind that (1) you want the application to be as secure as it can be, but also (2) any changes the development team has to make have costs in terms of time and money.

Be specific and support your recommendations.

Part 2: Binary SCA of Telegram Built From Source

I built the Telegram Linux desktop application from [its source](#). The BDBA analysis is here:

<https://protecode-sc.com/#/product/24174666/analysis>

Compare and contrast these results with the results from Part 1. What is different? Why are they different?

Be specific about components, versions, and vulnerabilities.

Part 3 Source SCA of OpenEMR

I built [the OpenEMR project](#), then had Black Duck analyze it. You can see the results in Black Duck, in the `openemr-interface` project version `0.2.0`:

<https://poc41.blackduck.synopsys.com/>

Like in Part 1, pretend you are a security engineer. What recommendations would you make to the development team? Keep in mind that (1) you want the application to be as secure as it can be, but also (2) any changes the development team has to make have costs in terms of time and money.

Be specific and support your recommendations.

Part 4: Policy

Write an SCA policy for an application. This should be about a page. Assume your audience is the development team.

First decide on an application, real or imaginary. Describe the application and outline what it does and what data it handles.

Then write an SCA policy. When, or how often, should SCA scans be done? What kind of results are acceptable? Can the application be released with CVEs in used components? What kinds of licenses are allowed or denied? Explain your choices.